



## Practica 6: KEYLOGGER

### 1. Introducción

A diferencia de las vulnerabilidades que son evitables siguiendo a pie de la letra políticas de seguridad que las previenen, un ataque de seguridad no es prevenible. Ya sea una empresa, una institución, individuo o incluso un gobierno, existe siempre una probabilidad de ser atacados. No se puede evitar, depende de los atacantes cibernéticos el si un ataque se efectúa o no, pero es responsabilidad de las víctimas intentar mitigar de alguna manera los riesgos del ataque.

Los atacantes cibernéticos cada año diseñan nuevos programas, más robustos, dañinos e indetectables, para enviarlo a alguna víctima con el fin de robar o causar daños intencionalmente y explotar datos de los sistemas de los afectados. A estos programas suelen nombrarlos como códigos maliciosos y son unos de los ataques más comunes en computación.

El malware (código malicioso) suele dividirse en spyware, keyloggers, rootkits, adware, entre otras categorías. Los piratas informáticos han transformado la realización de este software en una industria millonaria de ciberdelincuencia.

El malware está en constante evolución. Cada año los ataques aumentan en complejidad e impacto. Malware como Hawk Eye o Pegasus dirigido principalmente a usuarios comunes, se han convertido en tendencia alrededor del mundo con noticieros intentando cubrir todo el alcance de las ya consideradas armas informáticas.

Por ejemplo, en marzo del 2018, dos grupos de piratas informáticos pusieron en peligro a Cathay Pacific Airlines instalando lo que se conoce como keylogger, un programa que detecta, almacena y envía lo que se ha detectado en la consola del sistema. El programa fue instalado en el puerto de la consola del servidor de Cathay, lo que provocó este ataque el robo de información de identificación personal de 9.4 millones de pasajeros de Cathay [6]

Entre la información robada se tenían nombres, direcciones, números de teléfono, números de vuelo, datos, direcciones de correo electrónico y números de membresía.

Los keyloggers funcionan como muchos troyanos, están diseñados para imitar software legítimo y eludir escáneres antivirus o antimalware. Además, los keyloggers se ejecutan a un nivel de privilegio más alto de un malware típico, por lo que se vuelven casi imposibles de detectar o eliminar [1]

Registrar teclas como técnica no es nuevo. Este tipo de malware en un principio habían sido diseñados para propósitos legítimos, por ejemplo para evitar que los empleados ingresen información confidencial, pero el internet les dio un nuevo estilo de vida [3]

Un caso donde los keylogger fueron empleados con fines legítimos fue para la captura de Nicodemo Scarfo Jr., un mafioso estadounidense y miembro de la familia criminal Lucchese. Lucchese era una organización criminal que había sembrado terror en Nueva York y Filadelfia. Toda la organización fue identificada a través de un keylogger llamado Magic Lantern que el FBI instaló en su computadora de la organización a través de un troyano [12]

---

Magic Lantern registro cada pulsación de tecla realizada por Nicodemo Scarfo Jr y envió esa información a los federales, quien luego de aportar suficientes pruebas de una red de apuestas ilegales y usurpación de préstamos, fue detenido. No obstante, ya sea que se utilicen como herramienta de apoyo del FBI o simplemente para el robo de datos financieros, los keylogger representan una amenaza seria.

Cualquier persona y organización que acceda a información privada es vulnerable a que infrinja leyes importantes, como la Ley Federal de Protección de Datos Personales [7] o la Ley Sarbanes Oxley en Estados Unidos [11] por medio de keyloggers [2] por lo que es necesario conocer esta amenaza a profundidad.

## objetivos

### Generales:

Programar un keylogger utilizando el lenguaje de programación Python, con el fin de reconocer y generar conciencia sobre el alcance y daño del malware. En caso de identificar el uso deshonesto o ilícito de la información proporcionada, se reportará a las autoridades correspondientes

### Particulares

Aprender el uso de herramientas como keybinder para el desarrollo de un código malicioso, así como comprender el término de malware y sus variantes.

## requisitos

- **Conocimientos previos:** Fundamentos en programación de lenguajes orientado a objetos.
- **Tiempo de realización sugerido:** 4horas
- **Número de colaboradores:** 2
- **Software a utilizar:**
  - Python.
  - bash.
  - Keyboard.
  - Pyxhook.
  - Yagmail.
  - Keybinder.
  - smtplib.

## planteamiento

El software malicioso, malware, abarca toda la gama de virus, troyanos, keylogger, entre otros [8] Los keylogger se utilizan para muchos propósitos, desde monitorear al personal de una empresa, hasta el ciberespionaje. Comprender como funcionan es crucial si se desea asegurar la confidencialidad de una organización.

La función principal un keylogger es registrar en secreto las pulsaciones de teclas realizadas por un usuario. También debe lidiar con el uso de portapapeles e incorporándolos al protocolo cuando se detecta un comando de "pegar" [13] Los keylogger deben analizar lo recuperado para obtener los datos deseados.

Lo que se desea usualmente de un keylogger es capturar contraseñas, credenciales o comportamiento específico, como la entrada de datos en un formulario de un sitio web determinado.

---

Hoy en día encontramos los keyloggers como una herramienta para los padres para proteger a sus hijos de posibles peligros en la red. Instalar uno en una PC doméstica es relativamente fácil y difícil de detectar.

Los keylogger pueden ser una herramienta útil en el ámbito laboral, ya que sirven para controlar la entrada y salida de datos o para garantizar el buen uso de los mismos. El departamento de tecnología de la información o de seguridad de una empresa, puede usar keyloggers para la recopilación de datos en investigaciones internas o el control de correspondencia de los usuarios.

Los keylogger se clasifican en cuatro categorías básicas: hardware, acústico, inalámbrico y software [9]. El de tipo hardware es un circuito ubicado en el teclado y la CPU de la computadora. Capturan los datos antes que aparezcan en el CPU y son extremadamente difíciles de detectar mediante software, por lo que se necesita un examen físico para prevenirlos.

Los keyloggers inalámbricos son unidades físicas parecidas a los keylogger de hardware, pero con la única diferencia de que utilizan bluetooth para transferir los datos a un rango amplio dependiendo del keylogger.

Los acústicos realizan el ataque a través del teclado acústico. Cada teclado puede producir un sonido distinto según su tipo. Estos keylogger analizan el sonido para detectar contraseñas o números de tarjetas de crédito.

A lo largo de la práctica se enfocará únicamente en el último tipo, los keyloggers de software. Forman parte del malware, como botnets, troyanos o puertas traseras y se clasifican de dos maneras distintas de acuerdo a la forma en que obtienen los registros:[9]

- Keyloggers aislados/independientes: registran las actividades del usuario, pero no envían el archivo de registro al atacante. El atacante debe tener acceso físico al sistema para recuperar el registro.
- Keyloggers remotos: registran las actividades del usuario y envían el archivo de registro al atacante usando correo electrónico, FTP, redes compartidas, botnets, o servidores P2P.

Al igual que cualquier spyware, un keylogger tiene un ciclo de vida de tres etapas [13]:

1. Penetración del sistema: en esta etapa se realiza la operación de infección, por lo que se necesita acceso remoto o local a la PC.
2. Espiar: en esta etapa es importante que el keylogger no sea detectado.
3. Recuperar el registro: en esta etapa el ciberdelincuente tiene que obtener acceso a la PC o recuperar los datos de manera remota.

No solo las PC son amenazadas por los keyloggers, los teléfonos inteligentes han abierto nuevas posibilidades de riesgos potenciales para la privacidad del usuario y la infiltración de seguridad. Los teléfonos inteligentes son susceptibles a la infección de keyloggers. Usualmente, se explotan los sensores de movimiento para interferir en los toques de los usuarios en las pantallas táctiles [5]

Los keylogger son una arma utilizada por ambos bandos para proteger o vulnerar la seguridad. Es importante saber el impacto y alcance de estas herramientas para utilizarlas de la mejor manera posible. Por ejemplo, el FBI ha usado spywares para rastrear con éxito bombas y los gobiernos usualmente los emplean para combatir contra criminales peligrosos [4]

Si bien se podría discutir como profesionistas las consideraciones éticas que conllevan su uso, está claro que el uso continuará y se debe aprender el desarrollo de malware para finalmente prevenirlo. Esta práctica está enfocada en el desarrollo, explotación y prevención, de un keylogger considerando este tipo de malware como un atentado a la seguridad, más específicamente, a la confidencialidad.

---

## desarrollo

La práctica se enfoca en la realización de un software malicioso catalogado spyware y llamado keylogger.

Para llevar a cabo la práctica se utilizará bibliotecas de Python que tengan como objetivo proporcionar las llamadas a eventos globales de mouse y teclados en Linux o Windows. Las paqueterías que se recomiendan son keyboard, pyxhook o keybinder. Analiza las opciones y selecciona la herramienta adecuada para las necesidades de tu computador.

Estas herramientas facilitarán el registro de controladores de eventos, como es pulsar el botón izquierdo o derecho y la tecla hacia abajo, entre otros; sin embargo, no serán capaces de transmitir la información al menos que se consulte de manera local.

Se realizará un keylogger remoto, por lo que deberá transmitir la información recopilada al momento de ejecución del keylogger por medio de correo electrónico a los integrantes del equipo y ayudante del laboratorio. Para realizar esta acción, podrás utilizar herramientas como lo son yagmail o smtplib, ambas paqueterías de Python que envían correos electrónicos por medio del protocolo SMTP.

El keylogger deberá contar con una función llamada callback, la cual se encargara de registrar los eventos generados por el computador.

Contará de igual manera con una función llamada output, la cual se encargará de crear un archivo de texto plano añadiendo un registro local además del remoto (email). Al momento de ejecutar el keylogger, deberá mostrar un menú en la salida estándar el cual pregunte si se desea o no enviar el correo electrónico. También se preguntará si se desea o no guardar un registro en texto plano, y finalmente aceptará la bandera exit para detener la ejecución en cualquier momento.

Por último, deberá añadir un documento en bash el cual al ejecutarlo borre la práctica y todo rastro del programa. No olvides añadir un README donde anexarás las versiones de los elementos usados y el método de ejecución de la práctica.

## insumos

La práctica contará con un menú el cual acepte como respuesta yes o y y de igual manera, deberá poder recibir no o n a las siguientes preguntas:

- ¿Deseas enviar los registros por email?
- ¿Deseas guardar los registros en texto plano?

En caso de que se conteste con no a ambas preguntas, el programa deberá interrumpir su ejecución con algún mensaje. El programa deberá recibir también la bandera exit para terminar la ejecución inmediata del programa.

## producto final

Un archivo de texto plano llamado output, en el cual se registraron los eventos realizados. También el programa deberá enviar tres correos electrónicos con la misma información registrada en el output.

## actividad

Se entregará un programa en Python llamado keylogger que deberá funcionar en distribuciones de Unix/Linux. Además, entregar un programa en bash o algún otro shell que borre todo rastro del programa keylogger llamado Cleanup.

---

## preguntas

1. Menciona cuatro tipos de malware y explica su funcionamiento.
2. ¿Cómo funciona el malware llamado Pegasus?
3. ¿Cuál fue el alcance del malware WannaCry?
4. ¿Cuál sería las consecuencias si un malware con el mismo alcance del gusano de Morris nos infectara hoy en día [10]?
5. ¿Cómo previenes el malware?
6. Investiga sobre CovidLock. ¿Cómo funciona? ¿Cuál fue su alcance?
7. Menciona un caso donde un keylogger fuera usado lícitamente, no mencionado previamente.
8. Menciona un caso donde un keylogger creó conmoción por culpa de ciberdelincuentes, no mencionado previamente.
9. ¿Crees que es ético el uso de keylogger en el hogar? Espiando hijos, hermanos, padres o parejas.
10. ¿Crees ético el uso de keylogger en cualquier espacio, ya sea lícita o ilícitamente?

## entregables

Archivo en formato PDF con la realización detallada de la actividad, incluyendo las siguientes secciones:

- Recopilación: Donde se debe incluir todo lo que se necesita para la realización de la práctica. Por ejemplo, ¿qué lo que se quiere lograr? ¿Qué información es necesaria para ello? ¿Qué herramientas contamos? ¿Para qué?
- Método de creación y explotación: En esta etapa se documentará la creación del malware.
- Post-explotación: Anexarás todo lo obtenido mediante el malware y explicarás un método de prevenir el keylogger que se realizó.
- Alcance: En esta fase imagina todo lo que se puede realizar utilizando este programa. Explícalo detalladamente y reflexiona el alcance de lo que acabas de realizar y sus repercusiones.
- Referencias: Se debe incluir la bibliografía correspondiente en formato APA. El carecer de referencias invalidará la práctica entera. Deberá contener los datos obtenidos completos y debidamente explicados.

Se incluirá una sección de preguntas de refuerzo y una de referencias en formato APA. El carecer de referencias invalidará la práctica entera.

## Referencias

- [1] A. Bhardwaj and Sam Goundar. Keyloggers: silent cyber security weapons. *Network Security*, 2020. [https://doi.org/10.1016/S1353-4858\(20\)30021-0](https://doi.org/10.1016/S1353-4858(20)30021-0) doi:10.1016/S1353-4858(20)30021-0.
- [2] S. Chahrvin. Keyloggers – your security nightmare? *Computer Fraud & Security*, 2007. [https://doi.org/10.1016/S1361-3723\(07\)70090-8](https://doi.org/10.1016/S1361-3723(07)70090-8) doi:10.1016/S1361-3723(07)70090-8.

- 
- [3] S. Heron. The rise and rise of the keyloggers. *Network Security*, 2007. [https://doi.org/10.1016/S1353-4858\(07\)70052-1](https://doi.org/10.1016/S1353-4858(07)70052-1) doi:10.1016/S1353-4858(07)70052-1.
- [4] P. Hunter. FBI spyware admission opens can of worms. *Computer Fraud & Security*, 2007. [https://doi.org/10.1016/S1361-3723\(07\)70104-5](https://doi.org/10.1016/S1361-3723(07)70104-5) doi:10.1016/S1361-3723(07)70104-5.
- [5] M. Hussain, A. Al-Haiqi, A. A. Zaidan, B. B. Zaidan, M. L. Mat Kiah, N. Badrul Anuar, and M. Abdulnabi. The rise of keyloggers on smartphones: A survey and insight into motion-based tap inference attacks. *Pervasive and Mobile Computing*, 2016. <https://doi.org/10.1016/j.pmcj.2015.12.001> doi:10.1016/j.pmcj.2015.12.001.
- [6] D. Mok. Personal data of 9.4 million passengers of Cathay Pacific and subsidiary leaked, airlines say. South China Morning Post, October 2018. URL: <https://www.scmp.com/news/hong-kong/transport/article/2170076/personal-data-some-94-million-passengers-cathay-pacific-and>.
- [7] Servicios Parlamentarios, Secretaría de. Ley federal de protección de datos personales. Secretaría General, 2010.
- [8] M. Shema. *Seven Deadliest Web Application Attacks*. Syngress, Boston, 2010.
- [9] R. Sreenivas and R. Anitha. Detecting keyloggers based on traffic analysis with periodic behaviour. *Network Security*, 2011. [https://doi.org/10.1016/S1353-4858\(11\)70076-9](https://doi.org/10.1016/S1353-4858(11)70076-9) doi:10.1016/S1353-4858(11)70076-9.
- [10] Syngress. *Understanding the Threats: E-mail Viruses, Trojans, Mail Bombers, Worms, and Illicit Servers*, chapter 1. Syngress, Burlington, 2000. <https://doi.org/10.1016/B978-192899423-7/50005-7> doi:10.1016/B978-192899423-7/50005-7.
- [11] Wikipedia contributors. Ley sarbanes-oxley — Wikipedia, the free encyclopedia, 2024. [Online; accessed 28-October-2024]. URL: [http://es.wikipedia.org/w/index.php?title=Ley %20Sarbanes-Oxley&oldid=157753316](http://es.wikipedia.org/w/index.php?title=Ley%20Sarbanes-Oxley&oldid=157753316).
- [12] Wikipedia contributors. Nicky scarfo jr. — Wikipedia, the free encyclopedia, 2024. [Online; accessed 26-October-2024]. URL: [http://en.wikipedia.org/w/index.php?title=Nicky %20Scarfo %20Jr.&oldid=1249058289](http://en.wikipedia.org/w/index.php?title=Nicky%20Scarfo%20Jr.&oldid=1249058289).
- [13] O. Zaitsev. Skeleton keys: the purpose and applications of keyloggers. *Network Security*, 2010. [https://doi.org/10.1016/S1353-4858\(10\)70126-4](https://doi.org/10.1016/S1353-4858(10)70126-4) doi:10.1016/S1353-4858(10)70126-4.